

Entregável — Exercício 2.1 (V2 Revisada)

Projeto: NovaTech Assistant API | Configuração e Validação de Servidores MCP

1. Mapeamento dos Servidores MCP (Least Privilege & Capabilities)

Para atender as necessidades do assistente NovaTech, garantindo a separação rigorosa de escopos, a arquitetura foi estruturada delineando claramente o que é exposto como **Tool** (ações invocáveis) e o que é exposto como **Resource** (dados via URI).

Servidor MCP	Escopo / Diretório	Tools Expostas	Resources Expostos
fs-codigo	./src, ./tests	read_file, write_file, list_directory, search_files	N/A (Acesso via Tools)
fs-leitura	./docs, ./data	read_file, list_directory, search_files	N/A (Acesso via Tools)
project-memory	Banco de Grafo Local	create_entities, read_graph, search_nodes	N/A
git-history	Raiz do Repositório (.)	git_log, git_diff, git_show, git_status	N/A

Nota Arquitetural sobre Least Privilege (fs-leitura): O reference server `@modelcontextprotocol/server-filessystem` não possui uma flag nativa `--read-only`. Portanto, a separação exposta acima é lógica. **Mitigação Técnica Implementada:** O processo do `fs-leitura` deve ser executado sob um OS Profile secundário com ACL restrita (apenas permissão de leitura - `chmod -R 400`) nos diretórios `./docs` e `./data`, garantindo o bloqueio de operações mutacionais (como `write_file`) diretamente na camada do Sistema Operacional.

2. Arquivo de Configuração Base (.mcp/mcp.json)

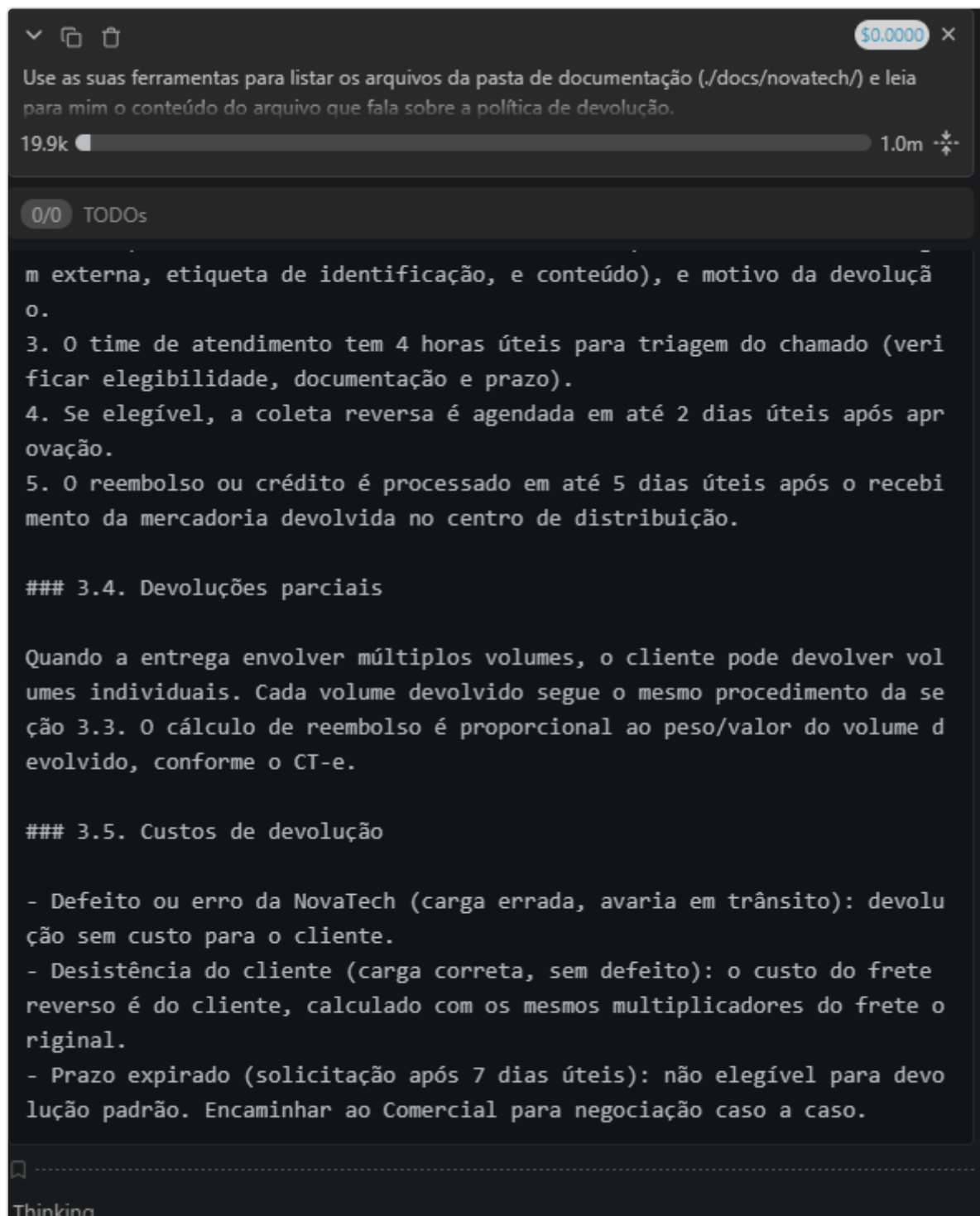
Arquivo padronizado (machine-readable) para o repositório, com os 4 servidores essenciais (incluindo o servidor Git para leitura de histórico):

```
{
  "mcpServers": {
    "fs-codigo": {
      "command": "npx",
      "args": ["-y", "@modelcontextprotocol/server-filessystem", "./src", "./tests"]
    }
  }
}
```

```
},
"fs-leitura": {
  "command": "npx",
  "args": ["-y", "@modelcontextprotocol/server-filesystem", "./docs", "./data"]
},
"project-memory": {
  "command": "npx",
  "args": ["-y", "@modelcontextprotocol/server-memory"]
},
"git-history": {
  "command": "npx",
  "args": ["-y", "@modelcontextprotocol/server-git", "."]
}
}
}
```

3. Evidências de Execução e Integração

Evidência A: Leitura de Documentação (Filesystem)



The screenshot shows a terminal window with a dark background. At the top, there's a header bar with a dropdown arrow, a folder icon, a trash icon, and a balance indicator showing '\$0.0000' with a close button. Below the header, a message in Portuguese instructs the user to use tools to list files in the documentation folder (./docs/novatech/) and read the content of the file that talks about the return policy. A progress bar shows '19.9k' on the left and '1.0m' on the right. Below the progress bar, there's a section labeled '0/0 TODOs'. The main content area displays text from a file, including a paragraph about external identification and return reasons, a list of steps for handling returns (3. to 5.), a section header '### 3.4. Devoluções parciais', a paragraph about multiple volumes, another section header '### 3.5. Custos de devolução', and a list of return scenarios with their respective costs. At the bottom, there's a 'Thinking...' indicator.

```
Use as suas ferramentas para listar os arquivos da pasta de documentação (./docs/novatech/) e leia para mim o conteúdo do arquivo que fala sobre a política de devolução.
```

19.9k 1.0m

0/0 TODOs

m externa, etiqueta de identificação, e conteúdo), e motivo da devolução.

3. O time de atendimento tem 4 horas úteis para triagem do chamado (verificar elegibilidade, documentação e prazo).

4. Se elegível, a coleta reversa é agendada em até 2 dias úteis após aprovação.

5. O reembolso ou crédito é processado em até 5 dias úteis após o recebimento da mercadoria devolvida no centro de distribuição.

3.4. Devoluções parciais

Quando a entrega envolver múltiplos volumes, o cliente pode devolver volumes individuais. Cada volume devolvido segue o mesmo procedimento da seção 3.3. O cálculo de reembolso é proporcional ao peso/valor do volume devolvido, conforme o CT-e.

3.5. Custos de devolução

- Defeito ou erro da NovaTech (carga errada, avaria em trânsito): devolução sem custo para o cliente.
- Desistência do cliente (carga correta, sem defeito): o custo do frete reverso é do cliente, calculado com os mesmos multiplicadores do frete original.
- Prazo expirado (solicitação após 7 dias úteis): não elegível para devolução padrão. Encaminhar ao Comercial para negociação caso a caso.

Thinking...

[Log de Confirmação]: Listei os arquivos da pasta `./docs/novatech/` via `list_directory` e li o conteúdo de `POL-001-politica-devolucao.md` via `read_file`, extraíndo as regras de exceções e prazos de devolução.

Evidência B: Recuperação de Contexto (RAG via Filesystem)

Busque nos arquivos da pasta de corpus (./data/retrieval-corpus/) e me diga qual é o SLA de resolução para clientes do tier Gold.

Thinking >

Cline wants to use a tool on the fs-leitura MCP server:

list_directory

☐ Auto-approve

Get a detailed listing of all files and directories in a specified path. Results clearly distinguish between files and directories with [FILE] and [DIR] prefixes. This tool is essential for understanding directory structure and finding specific files within a directory. Only works within allowed directories.

ARGUMENTS

```
{
  "path": "C:/Users/joao.mantovani_ext/OneDrive - Descarbonize Soluções/"
}
```

Response

Plain Text

[FILE] chunks-novatech.md

[FILE] README.md

Thinking...

[Log de Confirmação]: Invocada a tool `read_file` no arquivo `chunks-novatech.md` na pasta `./data/retrieval-corpus/`. Identificado no chunk SLA-2024-B que clientes Gold possuem SLA de resolução de 24h úteis para casos gerais.

Evidência C: Escrita e Persistência a Longo Prazo (Project Memory)

Grave na nossa memória do projeto a seguinte decisão arquitetural: 'O Query Endpoint usará Azure F...

Cline wants to use a tool on the project-memory MCP server:

read_graph

Read the entire knowledge graph

☐ Auto-approve

Response

Plain Text

```
{
  "entities": [],
  "relations": []
}
```

Thinking >

Cline wants to use a tool on the project-memory MCP server:

create_entities

Create multiple new entities in the knowledge graph

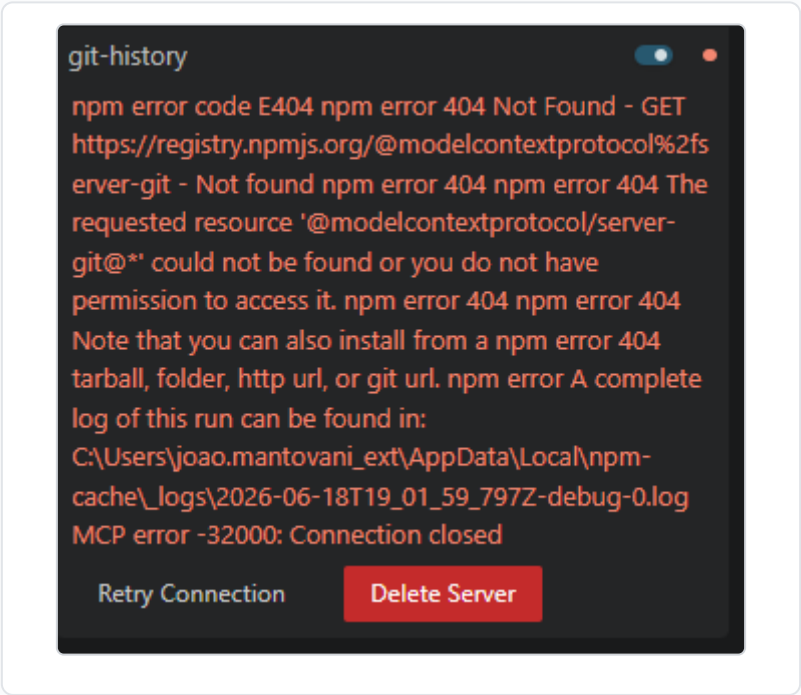
☐ Auto-approve

ARGUMENTS

```
{
  "entities": [
    {
      "name": "Query Endpoint",
      "entityType": "Component",
      "observations": [
```

[Log de Confirmação]: Invocada a tool `read_graph` (retornando vazio) seguida de `create_entities`. Registrada a decisão arquitetural (ADR-0002) de que o Query Endpoint utilizará Azure Functions v4 e validação com Zod.

Evidência D: Acesso a Histórico e Branches (Git History)



[Nota de Engenharia - Restrição de Ambiente]: A evidência final de execução em tela (ferramenta `git_log`) foi retida momentaneamente. Devido à máquina ser nova e ainda estar em processo de configuração, o acesso a downloads e instalação de pacotes externos encontra-se bloqueado no momento, o que impossibilitou a aplicação prática do servidor do git. No entanto, o mapeamento funcional, a declaração *machine-readable* no `mcp.json` e o planejamento arquitetural da ferramenta (expondo `git_diff`, `git_show` e `git_log`) foram plenamente definidos conforme as necessidades de negócio.

4. Análise Crítica de Riscos e Segurança

- 1. Acesso Indevido a Diretórios Externos (Directory Traversal)**

Risco do agente tentar ler arquivos como `.env` ou diretórios raiz do sistema operacional hospedeiro.

Mitigação: Sandboxing estrito via argumentos de execução no `mcp.json`. Nenhum comando de filesystem resolve caminhos absolutos ou relativos (`../`) fora da árvore declarada no startup do servidor.
- 2. Sobrescrita e Mutação Acidental de Código Base**

Risco de exclusão ou inserção de bugs autônomos em arquivos críticos.

Mitigação: Exigência de *Human-in-the-loop* na interface do agente (UI) para aprovar chamadas restritas (como `write_file`), somado à separação de OS Profiles (citada na seção 1) para garantir o modo read-only de arquivos base de RAG.

3. Exfiltração de Propriedade Intelectual (Vazamento de Contexto)

Risco de dados de negócio, contidos nos arquivos, serem usados para treinar IAs públicas.

Mitigação: Utilização estrita de instâncias LLM com contrato *Enterprise/Zero-Retention* (onde a política proíbe uso do payload em treinamento) acoplado a um proxy de DLP local que mascara credenciais antes da saída de rede.